

Database Security Policy

By Pratyush Bishowkarma



This policy defines the security controls required to protect organizational databases that support approximately 1500 employees and growing business operations. As the company continues to expand at a projected rate of 10% per year, protecting sensitive data such as financial records, employee data, and operational systems becomes more important.

The organization follows a defense-in-depth approach, meaning multiple layers of security are implemented across systems, networks, and user access. This ensures that if one

control fails, other controls remain in place to reduce risk. Both external threats and inside misuse are considered equally important in this policy.

Security Management

Security management focuses on controlling access and enforcing accountability. All database access must follow the principles of least privilege, where users are only granted permissions necessary for their job roles. Role-based access control is used to simplify and standardize permission management across departments.

Administrative access is tightly controlled. Database administrators must use separate privileged accounts instead of their regular user accounts. Multi-factor authentication is required for all administrative and remote access. Access rights are reviewed on a regular basis to ensure that unnecessary permissions are removed.

User onboarding and offboarding processes must include proper access provisioning and immediate revocation. This reduces the risk of unauthorized access, especially from former employees or internal misuse.

Physical Security

Physical security ensures that hardware and infrastructure hosting databases are protected from unauthorized access. On-premises SQL Server systems must be located in secure data centers with restricted entry, monitored through access logs and surveillance systems. Only authorized IT personnel are allowed physical access to these systems.

Backup storage devices, if used physically, must be encrypted and stored securely. For the cloud-based HR system, the organization relies on the provider's certified infrastructure, but still enforces strict access controls and data protection policies on its end.

Network Security

Network security is a critical layer in protecting database systems from unauthorized access. Database servers must always be deployed on a separate server from web servers. Hosting both on the same system creates a direct security exposure and increases the risk of compromise.

All database servers must reside in a private network segment and should never be directly accessible from the public internet. Firewalls are configured to strictly control traffic, allowing only approved systems to connect.

Special attention must be given to SQL Server's default port (TCP 1433). This port must be blocked by default and only opened for specific trusted IP addresses using an allowlist approach. Changing the default port may also be considered to reduce automated attack attempts, but it should not be treated as a primary security control.

All database communication must be encrypted using secure protocols such as TLS. Administrative access is only allowed through secure channels like VPNs or controlled jump servers. Network monitoring tools such as intrusion detection systems are used to identify unusual or suspicious traffic patterns.

Database Security

Database-level protection focuses directly on securing stored data and the database operations. Transparent Data Encryption (TDE) must be enabled to protect data at rest. For highly sensitive data such as social security numbers or payroll information, additional column-level encryption should be applied.

Authentication should rely on a centralized identity system, such as Active Directory, whenever possible. Default accounts and unnecessary features must be disabled to reduce the attack surface. Regular patching and updates are required to address known vulnerabilities.

Where possible, applications should interact with databases through stored procedures instead of direct table access. This limits exposure and reduces the risk of unauthorized data manipulation.

Access Control

Access control ensures that only authorized individuals can interact with database systems. Each user must have a unique account, and shared accounts are strictly prohibited. Access to the production database is restricted and requires proper approval.

Developers and non-administrative staff should not have direct access to production environments unless there is a valid business need. Segregation of duties must be enforced to prevent conflicts of interest, such as developers having administrative control over live systems.

Data Access Controls

Not all users should have visibility into all data. Sensitive information must be protected through techniques such as data masking and anonymization, especially in non-production environments.

Access to data can be further restricted using views, filters, and low-level security. This ensures users only see the data relevant to their role. Data exports must be controlled and logged to prevent unauthorized sharing or leakage of information.

Auditing and Logging

Auditing and logging provide visibility into database activity and are essential for detecting and responding to security incidents. SQL Server auditing must be enabled to capture login attempts, data access, and administrative actions.

All logs should be forwarded to a centralized logging or SIEM system for analysis. Regular reviews of logs are required to identify unusual behavior, such as repeated failed logins

or larger data access requests. Alerts should be configured to notify administrators of suspicious activities in real time. Without logging, it's almost impossible to figure out what went wrong after an incident.

Architectural Considerations

Systems architecture plays a major role in database security. A three-tier architecture must be followed, separating the presentation layer, application layer, and database layer. This reduces direct exposure of the database to end users.

Database servers and web servers must always be deployed on separate machines. This separation prevents attackers from easily accessing the database if the web server is compromised.

Integration with the cloud-based HR system must occur through secure APIs rather than direct database connections. Backup systems must also be isolated and regularly tested to ensure data can be recovered in case of failure.

Backup and Recovery Security

Backups are critical but can also introduce risk if not handled properly. All database backups must be encrypted to protect sensitive data. Access to backups is limited to authorized personnel only.

Backups should be stored securely, either off-site or in protected cloud storage. Regular testing of backup and recovery processes must be conducted to ensure data integrity and availability during incidents.

Conclusion

This policy establishes a layered security approach that protects databases through multiple controls across management, physical systems, networks, and data access. By

combining these layers, the organization reduces the risk of both external attacks and insider threats. Security is not a single solution but an ongoing process that requires monitoring, updates, and continuous improvement.

Summary of Cybersecurity Podcast

The Wealth is a Choise podcast dives deep into the modern landscape of cybercrime, specifically focusing on how the shift to remote work has create a spike in digital theft. The discussion highlights that working from public spance like coffee shops creates a high-density target environment where sensitive client dialogues and data are easily compromised. THis vulnerability is compounded by a lack of security check in professional sectors.

A significant portion of the conversation was dedicated to the cold reality of law enforcement limitation, particularly the concept of “minimum thresholds.” The guest speaker Dr. Greg Gogolin, explains that due to a massive gap between the number of crimes and investigative capacity, federal agencies like the FBI often won’t pursue a case unless the loss exceeds a high monetary floor, such as \$100,000 or \$600,000. Cybercriminals are acutely aware of these limits and often strategically keep their thefts just below these amounts to avoid triggering a federal response.

The podcast shows these risks through two upsetting case studies involving the exploitation of trust. In one case, a trusted accountant embezzled over \$1.5 million from a deceased person’s estate, onlu to die of a heart attack just weeks before his prosecution. In another case, a multi-millionaire in the Uper Peninsula was left penniless by his Power of Attroney, who sold off his assets while he was in Florida then later in a nursing home. Both stories shows that digital forensics is the only way to piece thse crimes together, yet they also serve as a warning about the fragility of evidence.

To fight these threats, Dr. Gogolin offers some simple yet practical security strategies. Beyond standard advice, he suggests using nonsensical answers for security questions like answering “my shoes are too big” instead of a mother’s maiden name, using app-based authenticators for two-factor-authentication. He also shares to use comma in passwords to break the scripts used by hackers to steal data. The podcast also goes to use some kind of family code word to verify identities in the age of AI voice cloning.

Dr. Gogolin also goes into the details of how he brought Cyber Security program into University. Where the digital forensics class was only for Criminal Justice major but later turned it into a whole major.